

Event Information:

The CVE-2023-29357 vulnerability is a critical privilege escalation vulnerability that, when combined with other vulnerabilities, could lead to remote code execution. A CVSS score of 9.8 (Critical) and

EventID :

189

Event Time :

Oct, 06, 2023, 08:05 PM

Rule :

SOC227 - Microsoft SharePoint Server Elevation of Privilege - Possible CVE-2023-29357 Exploitation

Level :

Security Analyst

Hostname :

MS-SharePointServer

Destination IP Address :

172.16.17.233

Source IP Address :

39.91.166.222

HTTP Request Method :

GET

Requested URL :

/_api/web/siteusers

User-Agent :

python-requests/2.28.1

Alert Trigger Reason :

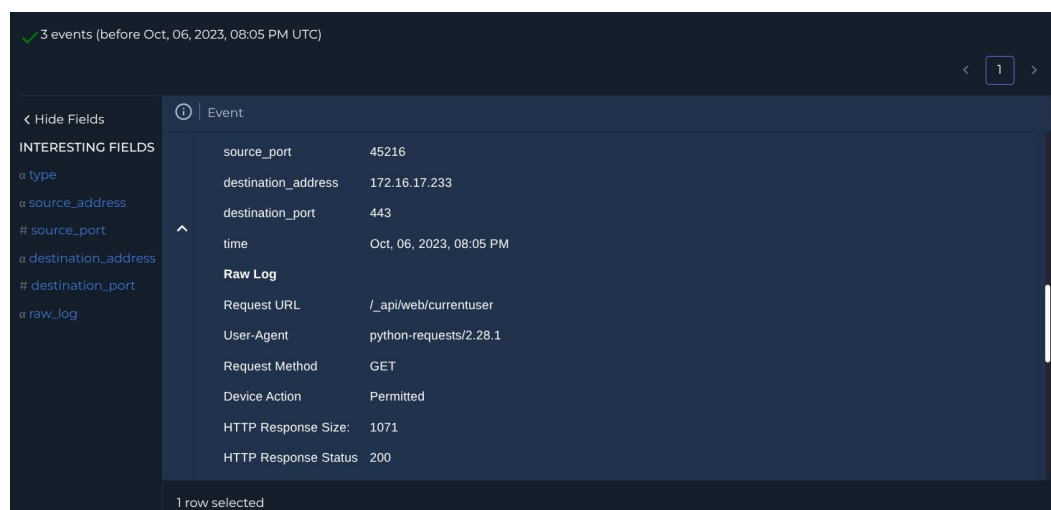
This activity may be indicative of an attempt to exploit the CVE-2023-29357 vulnerability, which could potentially lead to unauthorized access and privilege escalation within the SharePoint server.

Device Action :

Allowed

Analysis Steps:

Logs were searched with IP 39[.]91.166.222 as the source and MS-SharePointServer IP 172[.]16.17.233 as the destination in the relevant time-frame yielding 3 events.



3 events (before Oct, 06, 2023, 08:05 PM UTC)

Event	
source_port	45216
destination_address	172.16.17.233
destination_port	443
time	Oct, 06, 2023, 08:05 PM
Raw Log	
Request URL	/_api/web/currentuser
User-Agent	python-requests/2.28.1
Request Method	GET
Device Action	Permitted
HTTP Response Size:	1071
HTTP Response Status	200

1 row selected

CVE-2023-29357 is a critical Elevation of Privilege vulnerability. It allows an unauthenticated attacker to completely bypass authentication by sending a spoofed JSON Web Token (JWT). If successful, the server grants them the privileges of any user they choose (usually an administrator).

In the logs we can see:

1. The attacker initially sent a GET request to `/_api/web/siteusers/web/siteusers`. This attempt, however, failed due to what appears to be a typo receiving a 404 response.
2. Reconnaissance (200 OK): They quickly corrected the path and successfully queried `/_api/web/siteusers`. This forces the server to return a list of all valid SharePoint users, allowing the attacker to pick a target account to spoof.
3. Verification (200 OK): Finally, the attacker sent a GET request to `/_api/web/currentuser`. By returning a 200 OK, the server confirmed that the attacker's spoofed token was accepted and they are now actively authenticated as that user.

Responses are not easily visible in network logs so because the firewall permitted the traffic and the server responded with 200 OK success codes, this must be treated as a successful compromise.

The offending IP is in our CTI database with the source listed as anonymous.

DATE	DATA TYPE	DATA	TAG	DATA SOURCE
Oct, 09, 2023, 07:54 PM	IP	39.91.166.222	Malicious	Anonymous

The IP is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a Chinese address associated with 39[.]91.166.222 AS 4837 (CHINA UNICOM China169 Backbone). 2/91 security vendors flagged this IP address as malicious as of 5 days ago.

2
/ 91

Community
Score

2/91 security vendors flagged this IP address as malicious

39.91.166.222 (39.64.0.0/11)
AS 4837 (CHINA UNICOM China169 Backbone)

CN Last Analysis Date
5 days ago

REANALYZE

MORE

DETECTION

DETAILS

RELATIONS

COMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Do you want to automate checks?

BitDefender	Phishing	G-Data	Phishing
Avast	Clean	Acronis	Clean
ADMINUS Labs	Clean	All Labs (MONITORAPP)	Clean

On AbuseIPDB this IP was reported 1,430 times with a 0% confidence of abuse.

39.91.166.222 was found in our database!

This IP was reported **1,430** times. Confidence of Abuse is **0%**: ?

0%

ISP	China Unicom Shandong province network
Usage Type	Fixed Line ISP
ASN	AS4837
Domain Name	chinaunicom.cn
Country	 China
City	Qingdao, Shandong

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a successful True Positive exploit of CVE-2023-29357 (Elevation of Privilege) targeting the host MS-SharePointServer (172[.]16.17.233). An external threat actor successfully bypassed authentication by issuing spoofed JSON Web Tokens (JWT) to the SharePoint API. Network logs confirm the server accepted the tokens, granting the attacker unauthorised access to the instance.

Incident Details

- **Alert Name:** SOC227 - Microsoft SharePoint Server Elevation of Privilege - Possible CVE-2023-29357 Exploitation
- **Target Host:** MS-SharePointServer (172[.]16.17.233)
- **Attacker IP:** 39[.]91.166.222
- **Device Action:** Allowed

Analysis and Evidence

- **Attack Execution:** The attacker initially attempted a GET request to `/_api/web/siteusers/web/siteusers` but received a 404 response due to an apparent typo.
- **Reconnaissance:** The attacker corrected the path and successfully queried `/_api/web/siteusers`, receiving a 200 OK response. This forced the server to return a list of valid SharePoint users, allowing the attacker to select a target account to spoof.
- **Exploit Validation:** The attacker sent a final GET request to `/_api/web/currentuser`. The server returned a 200 OK response, confirming the spoofed JWT was accepted and the attacker was actively authenticated as the target user. Given that the firewall permitted the traffic and the server returned success codes, the most prudent course of action is to treat this as a confirmed compromise.

Threat Intelligence

- **OSINT (Infrastructure):** The attacking IP (39[.]91.166.222) is external to the organisation and resolves to the China Unicom Shandong province network (AS4837) in Qingdao, China.
- **Reputation:** The IP is flagged as malicious in the internal CTI database. VirusTotal flags it with 2/91 vendor detections, and AbuseIPDB lists 1,430 reports, indicating a history of scanning and abuse.
- **Internal Correlation:** No internal communications indicate authorised Red Team testing involving this IP during the relevant time-frame.

Actions Taken

1. Analysed firewall logs to identify the exploit sequence targeting the SharePoint API.
2. Verified the authentication bypass by correlating the 200 OK HTTP response codes returned by the server during the validation phase.
3. Investigated the attacker infrastructure via OSINT (VirusTotal, AbuseIPDB), confirming the IP is associated with known threat activity originating from China.
4. Declared the alert a successful True Positive compromise and escalated.

Let's Defend Result

SOC227 - Microsoft SharePoint Server Elevation of Privilege - Possible CVE-2023-29357 Exploitation
True Positive (+5 Point)
Was the Attack Successful? (+5 Point)
What Is the Direction of Traffic? (+5 Point)
Check If It Is a Planned Test (+5 Point)
What Is The Attack Type? (+5 Point)
Is Traffic Malicious? (+5 Point)